

CHAPTER 5: MANDATORY ACCESS CONTROLS

Le Thi Bao Thu

Faculty of Computer Science & Engineering

HCMC University of Technology

thule@hcmut.edu.vn

Outline

-
- 1 Introduction to MAC**
 - 2 Proposed Models for MAC
 - 3 Case study: Oracle Label Security (OLS)
-

Introduction to MAC

- ❑ **MAC: Mandatory Access Control**
- ❑ MAC is applied to large amounts of information requiring ***strong protect*** in environments where both the **system data** and **users** can be **classified** clearly.
- ❑ MAC is a mechanism for enforcing **multiple level** of security.

Introduction to MAC

- ❑ Introduction to MAC
 - **Security Classes**
 - MAC Properties
 - Multilevel Relation
 - Pros and Cons of MAC

Security Classes

- ❑ Each subject/object is assigned a security class corresponding to its role in the system.
- ❑ Security class comprise:
 - A classification level.
 - A set of categories.
- ❑ A **subject classification** reflects its degree of **trust** and the **application area** where it operates.
- ❑ A **object classification** reflects the **sensitivity** of the information and the **application area** to which the information refers.

Security Classes - Classification Levels

❑ Typical classification levels are:

- Top secret (TS)
- Secret (S)
- Confidential (C)
- Unclassified (U)

Where TS is the highest level and U is the lowest:

$$TS \geq S \geq C \geq U$$

Security Classes - Categories

- ❑ **Categories** (application areas) tend to reflect the **system areas** or **departments** of the organization.
- ❑ **Examples:**
 - Military environments: Nuclear – NATO – Intelligence.
 - Industrial environments:
 - Production – Personnel – Engineering – Administration.
 - Production – Sales – Delivery.

Security Classes - Partial Order

- ❑ A security class is defined as follow:

$$SC = (A, C)$$

- A: classification level
- C: category

- ❑ A relation of **partial order** on the security classes:

$$SC \leq SC' \leftrightarrow A \leq A' \text{ and } C \subseteq C'$$

- ❑ Examples:

$$(2, \text{Sales}) \leq (3, (\text{Sales}, \text{Production}))$$

$$\textcolor{red}{(2, (\text{Sales}, \text{Production})) \not\leq (3, \text{Sales})}$$

Introduction to MAC

- ❑ Introduction to MAC
 - Security Classes
 - **MAC Properties**
 - Multilevel Relation
 - Pros and Cons of MAC

MAC Properties

- ❑ **Simple security property (ss-property):** A subject S is not allowed to read an object O unless

$$\text{class}(S) \geq \text{class}(O)$$

→ **No read-up**

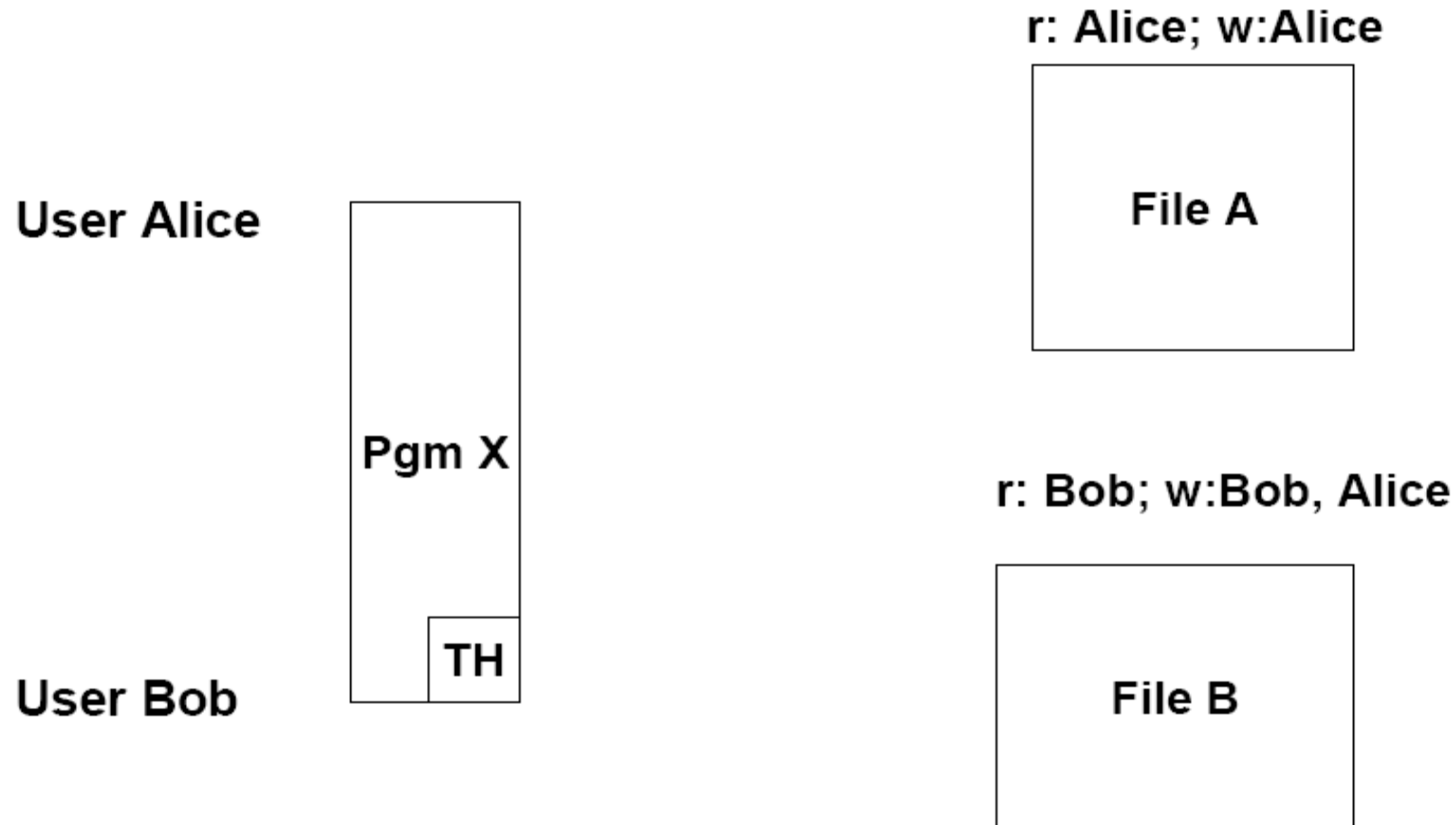
- ❑ **Star property (or * property):** A subject S is not allowed to write an object O unless

$$\text{class}(S) \leq \text{class}(O)$$

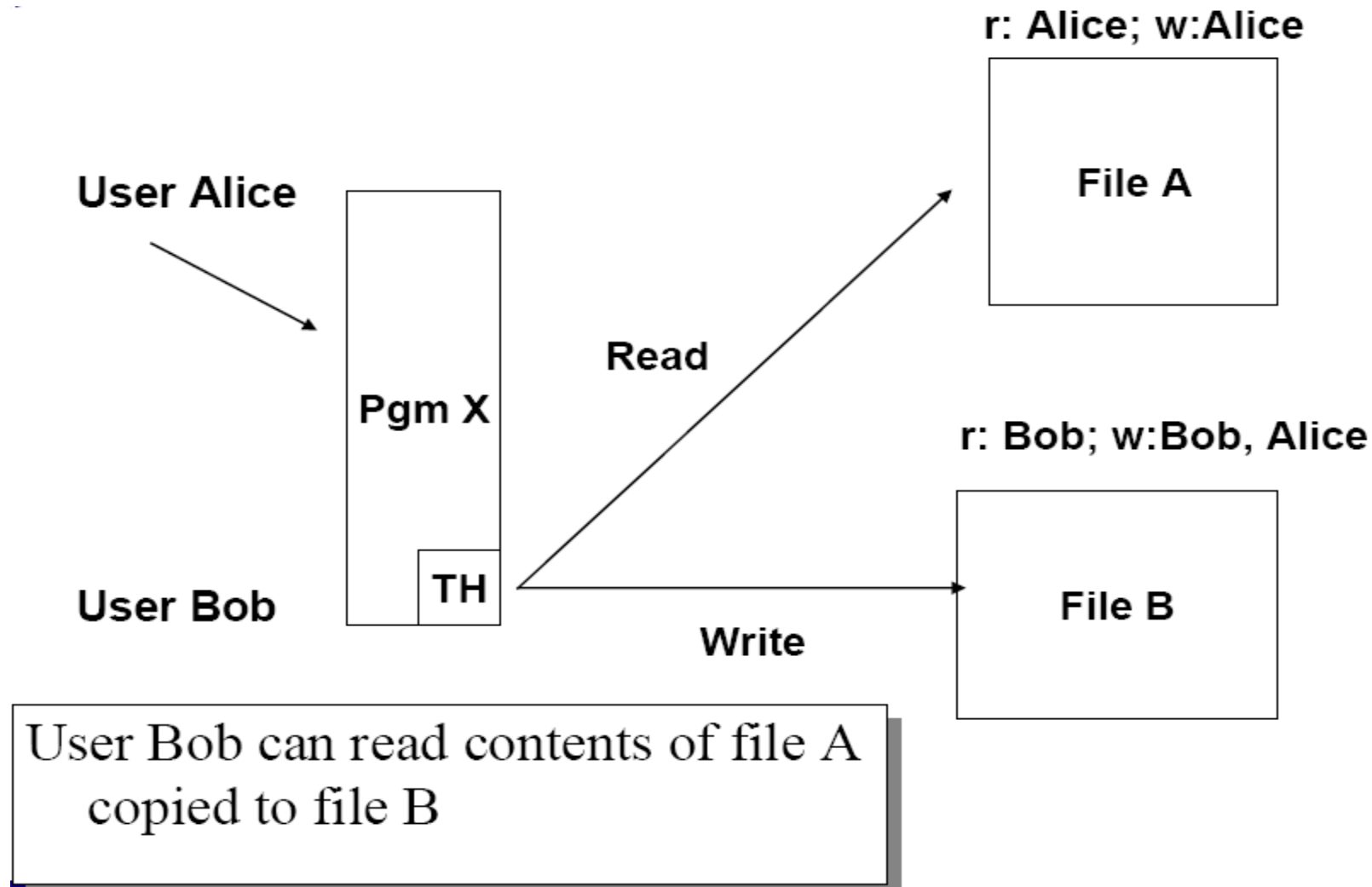
→ **No write-down**

→ *These restrictions together ensure that there is no direct flow of information from high secure objects to low ones!!!*

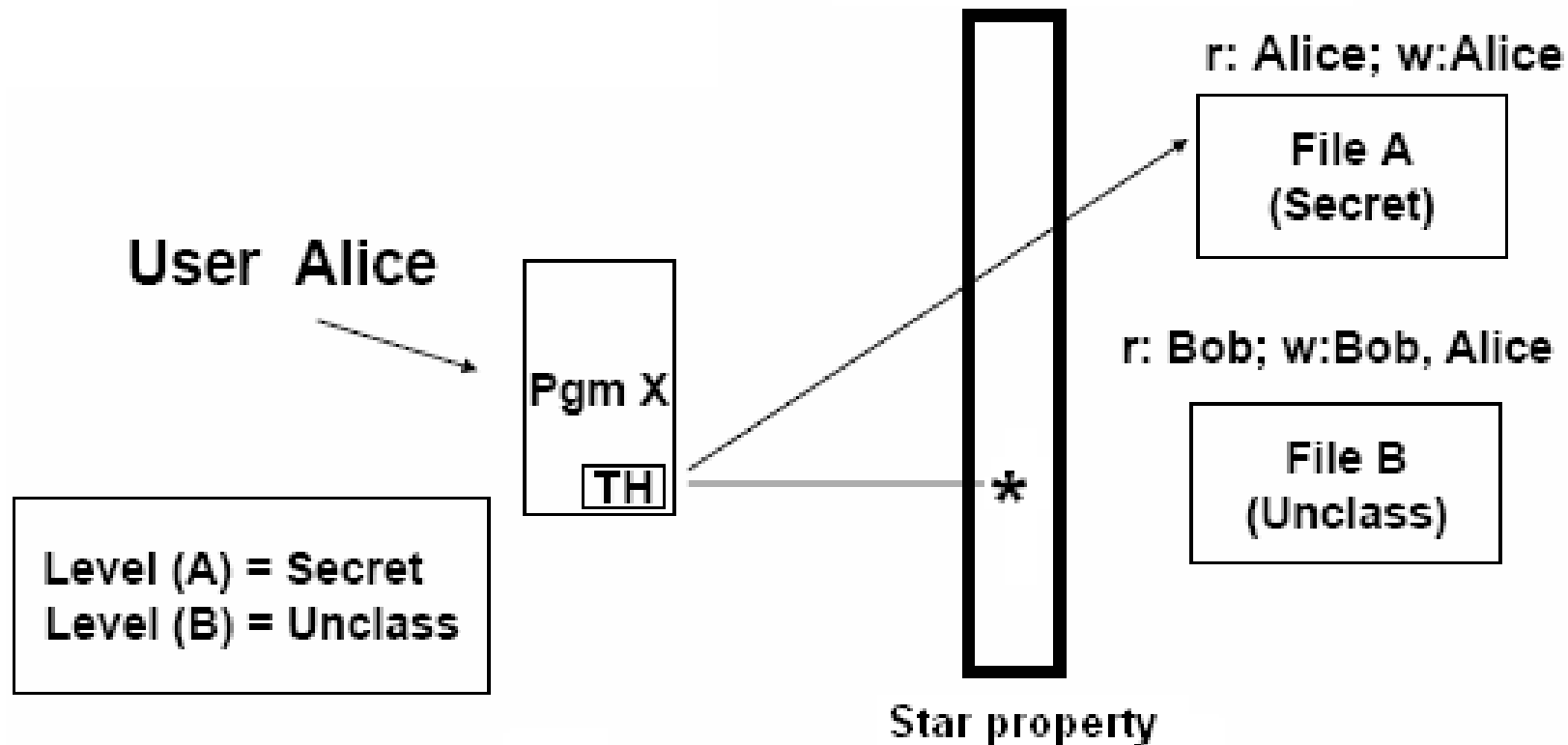
MAC Properties - Why Star Property? (1)



MAC Properties - Why Star Property? (2)



MAC Properties - Why Star Property? (3)



MAC Properties - Star Property Problem

- ❑ Problem: Star property prevents a subject at high secure class from sending a valid message to a subject at low secure class.
- ❑ Solutions:
 - Downgrade temporarily the security class of the subject when sending the valid messages.
 - Place trusted subjects in the subject list which is not enforced by Star Property.

Introduction to MAC

- ❑ Introduction to MAC
 - Security Classes
 - MAC Properties
 - **Multilevel Relation**
 - Pros and Cons of MAC

Multilevel Relation

- ❑ Multilevel relation: **MAC + relational database model.**

→ Deal with multilevel data.

- ❑ Data objects: attributes, tuples.

- ❑ A multilevel relation is represented by a schema:

$$R(A_1, C_1, A_2, C_2, \dots, A_n, C_n, TC)$$

- Each data attribute A_i is associated with a **classification attribute C_i** .
- Each tuple is associated with a **tuple classification attribute TC**.
→ TC is equal to the highest of all attribute classification values.

- ❑ The **apparent key** of a multilevel relation is the set of attributes that would have formed the *primary key* in a *regular (single-level) relation*.

Multilevel Relation - Example (1)

- Subjects with different classes may retrieve data from a multilevel relation but will see different versions that data.

EMPLOYEE

$S > C > U$

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

Multilevel Relation - Example (2)

SELECT * FROM EMPLOYEE;

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

❑ A user with security level S:

Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

Multilevel Relation - Example (3)

SELECT * FROM EMPLOYEE;

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

❑ A user with security level C:

Smith	U	40000	C	Null	C	C
Brown	C	Null	C	Good	C	C

Multilevel Relation - Example (4)

SELECT * FROM EMPLOYEE;

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

❑ A user with security level U:

Smith	U	Null	U	Null	U	U
-------	---	------	---	------	---	---

Multilevel Relation - Properties (1)

- ☐ Read and write operations.
- ☐ Entity integrity.
- ☐ Polyinstantiation.

Multilevel Relation - Properties (2)

❑ Read and write operations

- No Read-Up.
- No Write-Down.

→ Basic properties of MAC

Multilevel Relation - Properties (3)

❑ Entity integrity:

- All attributes that are members of the *apparent key* **must not be null** and must have the **same security classification** within each individual tuple.
- All the other attribute values in the tuple must have a security classification greater than or equal to that of the apparent key.

→ This constraint ensures that a user can see the key if the user is permitted to see any part of the tuple at all.

Multilevel Relation - Properties (4)

- ❑ Other integrity rules: **null integrity** and **interinstance integrity**.

Multilevel Relation - Properties (5)

- ❑ **Polyinstantiation:** where several tuples can have the same apparent key value but have different attribute values for users at different classification levels.
 - **Entity Polyinstantiation** arises whenever a subject inserts a new tuple that has the apparent key as of an existing but invisible tuple.
 - **Attribute Polyinstantiation** arises whenever a subject updates what appears to be a null element in a tuple, but which actually hides data with a higher (or incomparable) access class.

Multilevel Relation - Properties (6)

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

❑ A user with security level C

Smith	U	40000	C	Null	C	C
Brown	C	Null	C	Good	C	C

- A user with security level C tries to update the value of JobPerformance of Smith to 'Excellent':

```
UPDATE EMPLOYEE  
SET JobPerformance = 'Excellent'  
WHERE Name = 'Smith';
```



Multilevel Relation - Properties (6)

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Smith	U	40000	C	<i>Excellent</i>	C	C
Brown	C	80000	S	Good	C	S

Introduction to MAC

- ❑ Introduction to MAC
 - Security Classes
 - MAC Properties
 - Multilevel Relation
 - **Pros and Cons of MAC**

Pros and Cons of MAC

❑ Pros

- Provide a high degree of protection – in a way of preventing any illegal flows of information.
- Suitable for military types of applications.

❑ Cons

- Not easy to apply: require a strict classification of subjects and objects into security levels.
- Applicable for very few environments.

Outline

-
- 1 Introduction to MAC
 - 2 Proposed Models for MAC**
 - 3 Case study: Oracle Label Security (OLS)
-

Bell-LaPadula Model

- ❑ Developed by David Elliot Bell and Leonard J. La Padula in 1973.
- ❑ To standardize rules of multilevel security system (MLS) of *United States Department of Defense*.
- ❑ Used for enforcing access control in government and military applications.
- ❑ An extension of the Access Matrix Model.
- ❑ Oriented to protection in OS environments.

Bell-LaPadula Model - Access Modes

- ❑ Access modes executable by subjects on objects
 - *Read-only* (generally referred to as 'read').
 - *Append*: to append information to an object without seeing its contents (writing without reading).
 - *Execute*: to execute an object (program).
 - *Read-write*: to write into an object; allow the subject to see the contents of the object (generally referred to as 'write').

Bell-LaPadula Model - System State

- The state of the system is described by the 3-tuple:

$$v = (b, M, f)$$

- b : the **current access set**

→ $b = \langle \text{subject}, \text{object}, \text{access mode} \rangle = \langle s, o, m \rangle$: subject s has current access to object o in m mode.

- $M[s, o]$: the access matrix describes the access modes each subject can execute on each object.
- f : a level function associates each subject/object with its security level.

$$f: O \cup S \rightarrow L$$

- $f_o(o)$: the security level of object o
- $f_s(s)$: the clearance of subject s
- $f_c(s)$: the current level of subject s

$$f_c(s) \leq f_s(s)$$

Bell-LaPadula Model - Simple Security Property

❑ Simple Security Property (*No read up*)

- A **subject** may have read or write access to an object only if the clearance of the subject dominates the security level of the object.

❑ A system state $v = (b, M, f)$ satisfies the ss-property if, and only if:

For each $M[s, o]$:

$$\{read\} \text{ or } \{write\} \in M[s, o] \Rightarrow f_o(o) \leq f_s(s)$$

Bell-LaPadula Model - Star Property

❑ Star Property (*No read up* and *No write down*)

- An **untrusted** subject may have **append** access to an object if the security level of the *object* **dominates** the security level of the *subject*.
- An **untrusted** subject may have **write** access to an object only if the security level of the *object* is **equal** to the current security level of the *subject*.
- An **untrusted** subject may have **read** access to an object only if the security level of the *object* is **dominated** the current security level of the *subject*.

❑ A system state $v = (b, M, f)$ satisfies the *-property if, and only if:

- $append \in M[s, o] \Rightarrow f_c(s) \leq fo(o)$
- $write \in M[s, o] \Rightarrow f_c(s) = fo(o)$
- $read \in M[s, o] \Rightarrow f_c(s) \geq fo(o)$

Bell-LaPadula Model - Disadvantages

- ❑ Only enforces the *confidentiality property*, **not** the *integrity property*.
 - ❑ No flexibility in changing access levels.
 - ❑ Not prevent **convert channel**
 - No support for *polyinstantiation*.
- Biba model: **No read down, No write up**

Biba Model

- ❑ Proposed by Biba in 1977.
- ❑ Focus on protection of information integrity level.
- ❑ Each subject and each object is assigned a classification named *integrity level*.
- ❑ Typical integrity levels
 - Crucial (C)
 - Very Important (VI)
 - Important (I)

$$C > VI > I$$

Biba Model - Access Modes

- ❑ Modify: to write information in an object.
- ❑ Invoke: is a right between 2 subjects allowing these subjects to communicate.
- ❑ Observe: to read information in an object.
- ❑ Execute: to execute an object (program).

Biba Model - Integrity Policies (1)

- ❑ $i(s)$: integrity level of subject s
- ❑ $i(o)$: integrity level of object o
- ❑ **Simple Integrity Property**: a subject s can hold “observe” on an object o if and only if:

$$i(s) \leq i(o)$$

→ *No read down*

- ❑ **Integrity Star Property**: a subject s can hold “modify” an on object o if and only if:

$$i(o) \leq i(s)$$

→ *No write up*

Biba Model - Integrity Policies (2)

- ❑ **Invocation Property:** a subject can hold “invoke” to another subject if and only if:

$$i(s_2) \leq i(s_1)$$

Biba Model

- ❑ Biba model provides **integrity** protection but does not provide **secrecy** protection
 - It needs to be combined with other models.
- ❑ Lipner model is a combination of Bell-LaPadula model and Biba model.

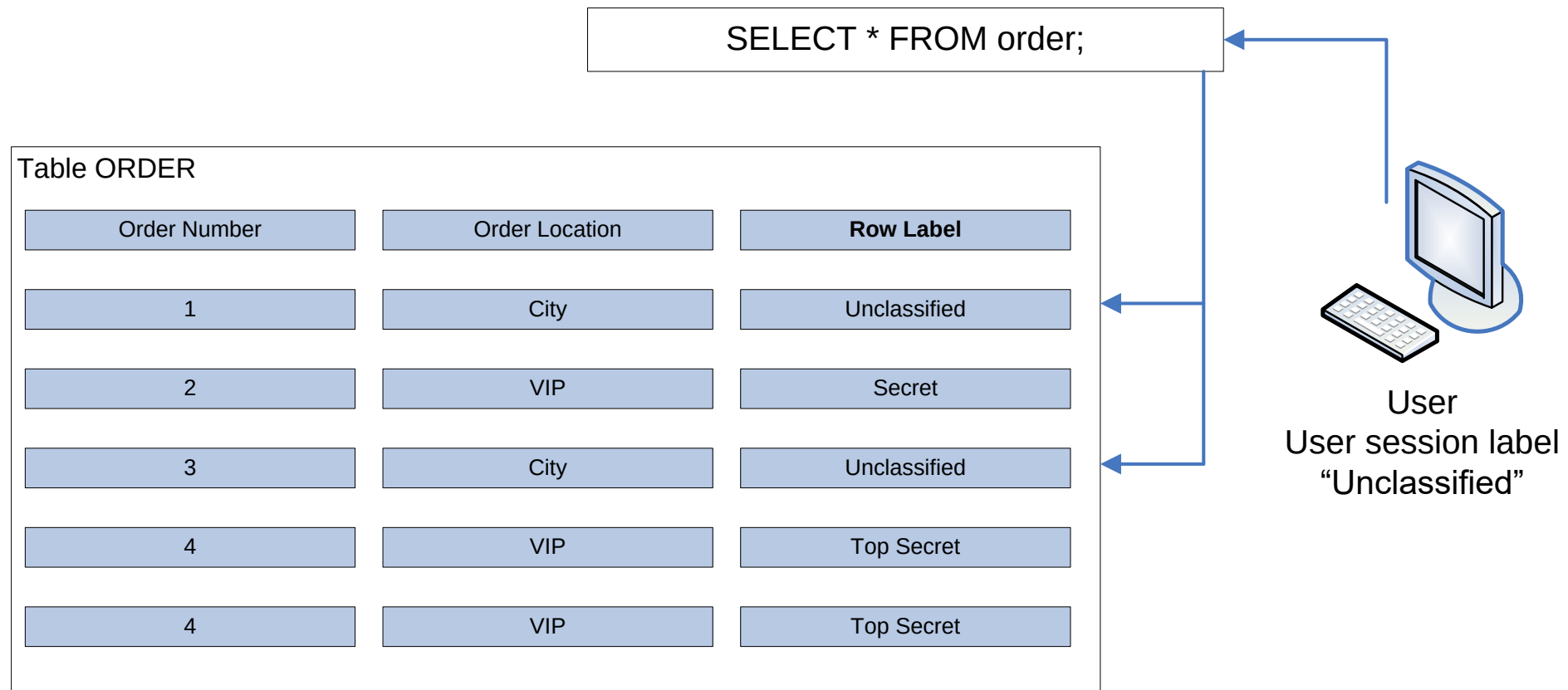
Outline

-
- 1 Introduction to MAC
 - 2 Proposed Models for MAC
 - 3 Case study: Oracle Label Security (OLS)**
-

OLS - Introduction (1)

- ❑ Simulates **multilevel** DB (MAC).
- ❑ Adds a field for each row to store the row's **sensitive label**.
- ❑ Access is granted (or denied) comparing user's **identity** and security **clearance label** with row's sensitive label.

OLS - Introduction (2)



OLS - Introduction (3)

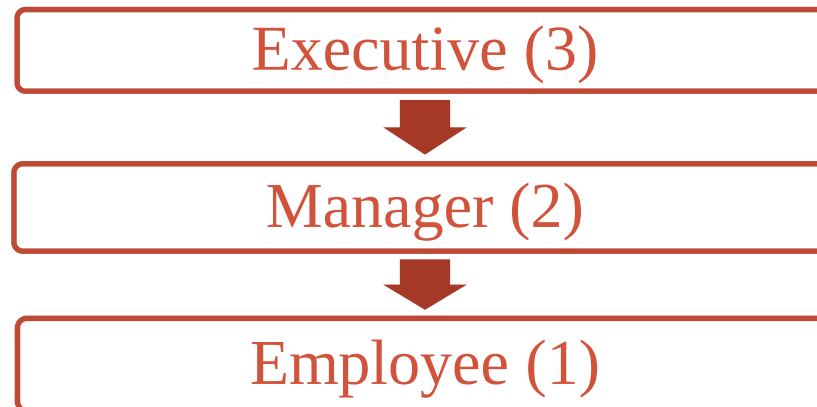
- ❑ Four aspects of label-based access control:
 - A user's label.
 - A row's label.
 - A user's policy privileges.
 - A table's policy enforcement options.

Label Components

- ❑ A label contains three components:
 - A single level (sensitivity) ranking.
 - Zero or more horizontal compartments.
 - Zero or more hierarchical groups.

Level

- ❑ Levels represent a hierarchy of data sensitivity.
- ❑ The primary mechanism to exclude users who are not authorized to see or alter certain data.
- ❑ Example:
 - Employee (1)
 - Manager (2)
 - Executive (3)

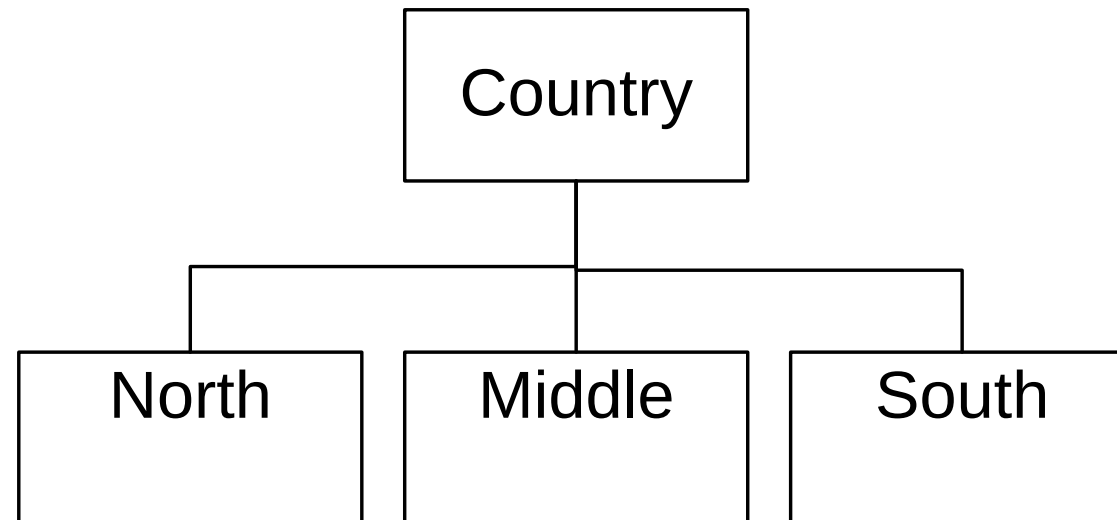


Compartment

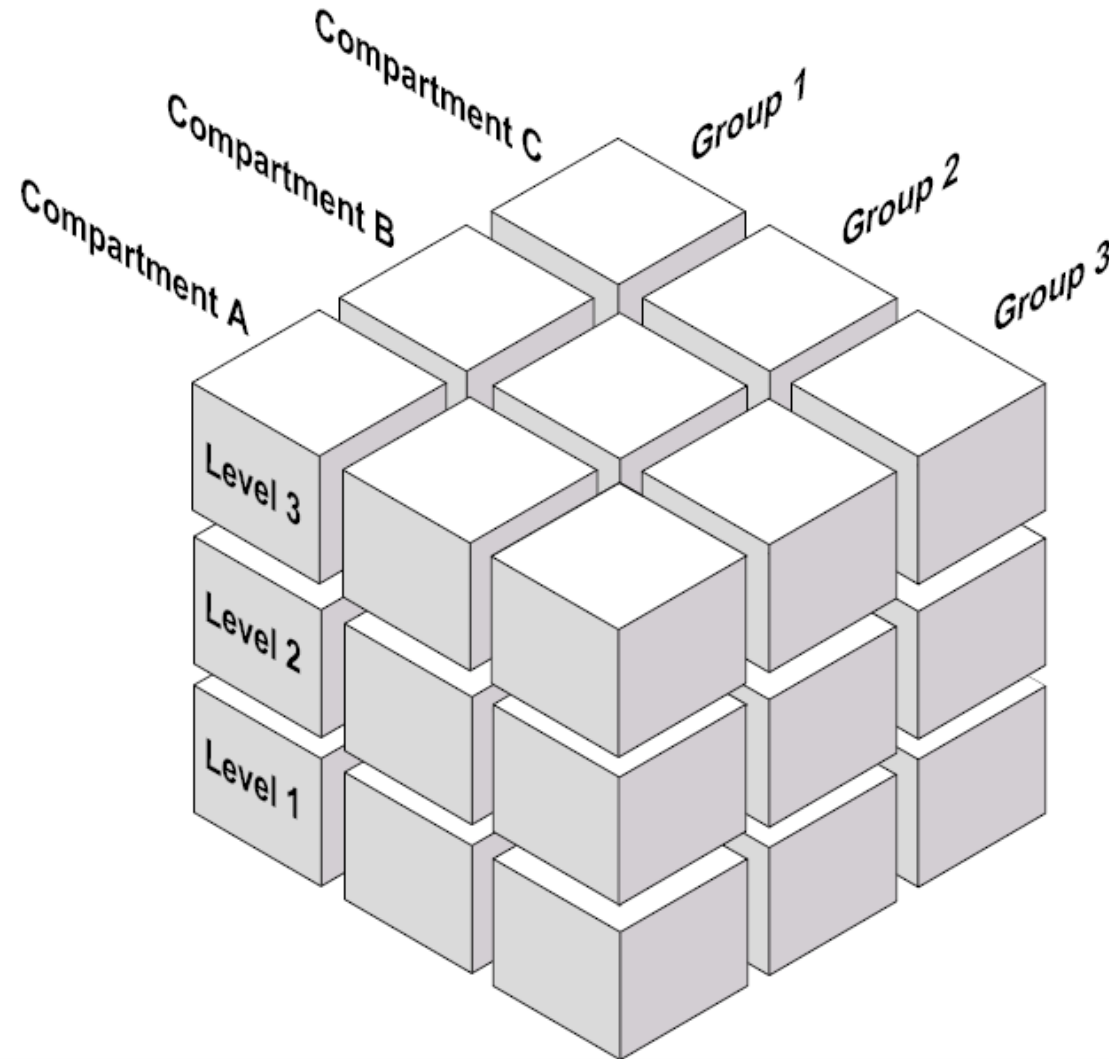
- ❑ The compartment component is not hierarchical.
- ❑ Compartments identify areas that describe the sensitivity of the labeled data, providing a finer level of granularity within a level.
- ❑ Example:
 - FOOD, CLOTHS, ELECTRICAL GOODS.

Group

- ❑ The group component is hierarchical and is used to identify organizations owning or accessing the data.



Label Components (1)



Label Components (2)

❑ Label syntax

LEVEL : COMPARTMENT₁,...,COMPARTMENT_n : GROUP₁,...,GROUP_n

❑ Example:

- MGR:CS:NA
- EXEC:CS,ES,FS:NA

Level:

MGR: Manager

EXEC: Executive

Compartment:

CS: Cloths

ES: Electrical Goods

FS: Food

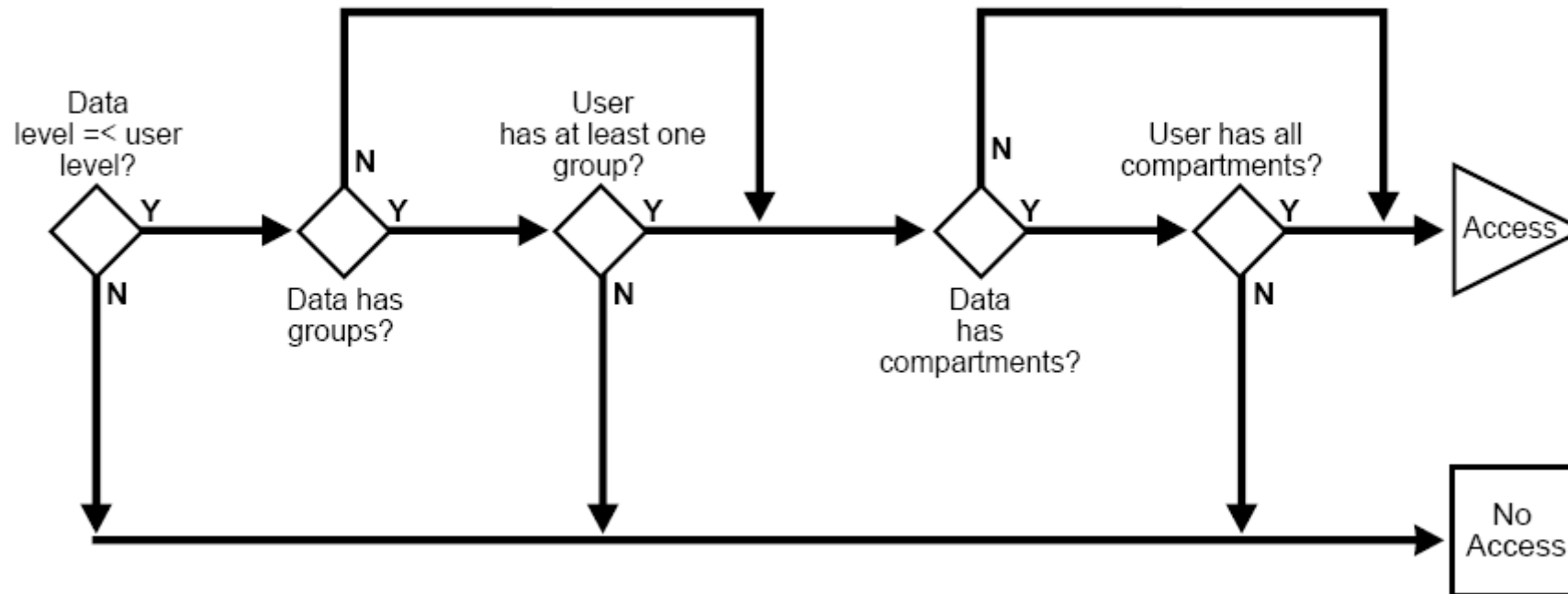
Group:

NA: North

User Access

- ❑ A user can only access data within the range of his or her own label authorizations .
- ❑ A user has:
 - maximum and minimum levels.
 - a set of authorized compartments.
 - a set of authorized groups.
 - a specification of read-only access or read/write access for each compartment and group.
- ❑ How to map user label and data label?

Read Access



Example:

Data Label:

- 1 Quoc
- 2 Thai
- 3 Dan
- 4 An

MGR:CS:NA
MGR:FS:NA
EMP:CS:NA
EMP: :

User label: MGR:CS:NA
User label: EMP:FS:NA
User label: EMP: :NA

Write Access

Example:

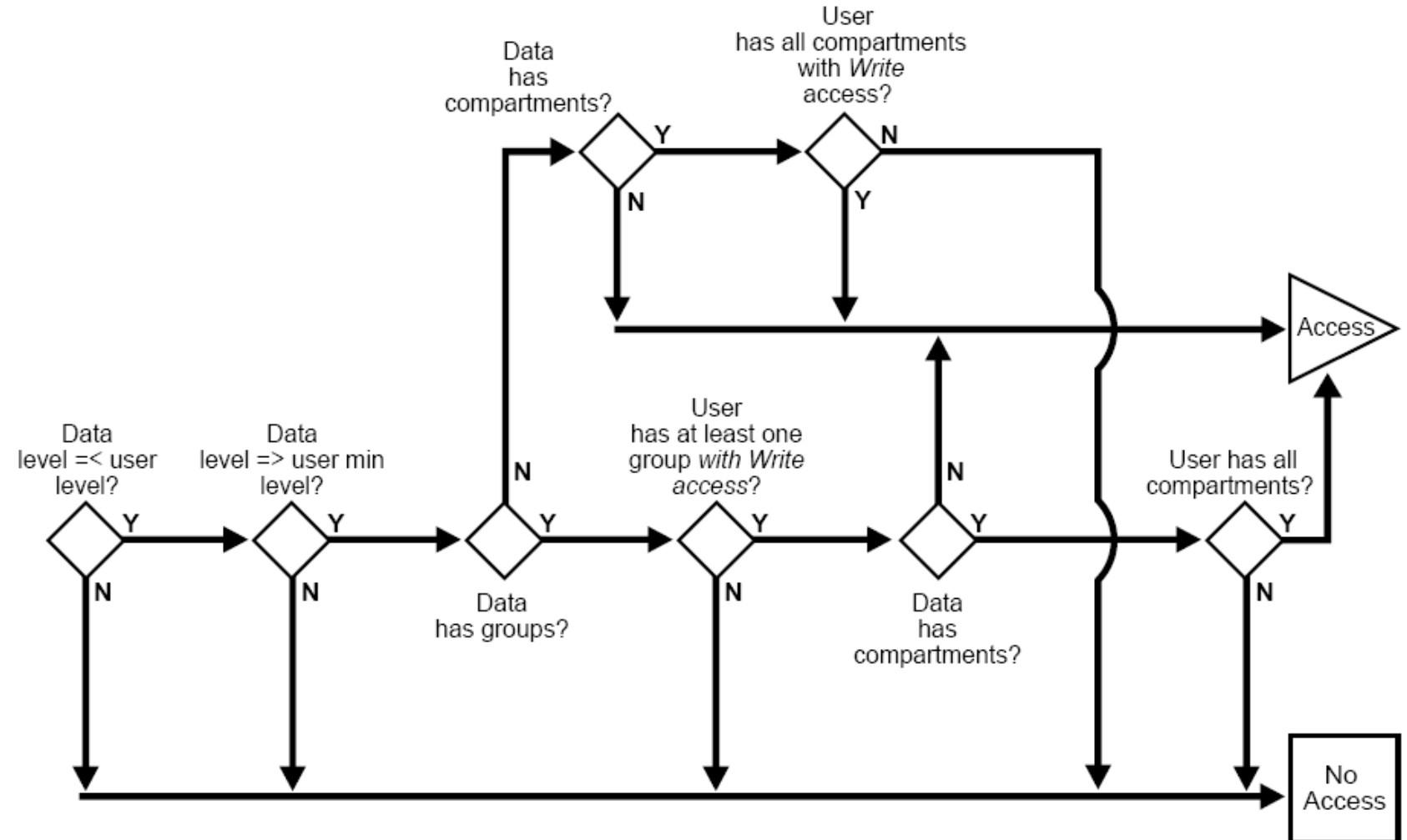
Data Label:

1	Quoc	MGR:CS:NA
2	Thai	MGR:FS:NA
3	Dan	EMP:CS:NA
4	An	EMP: :

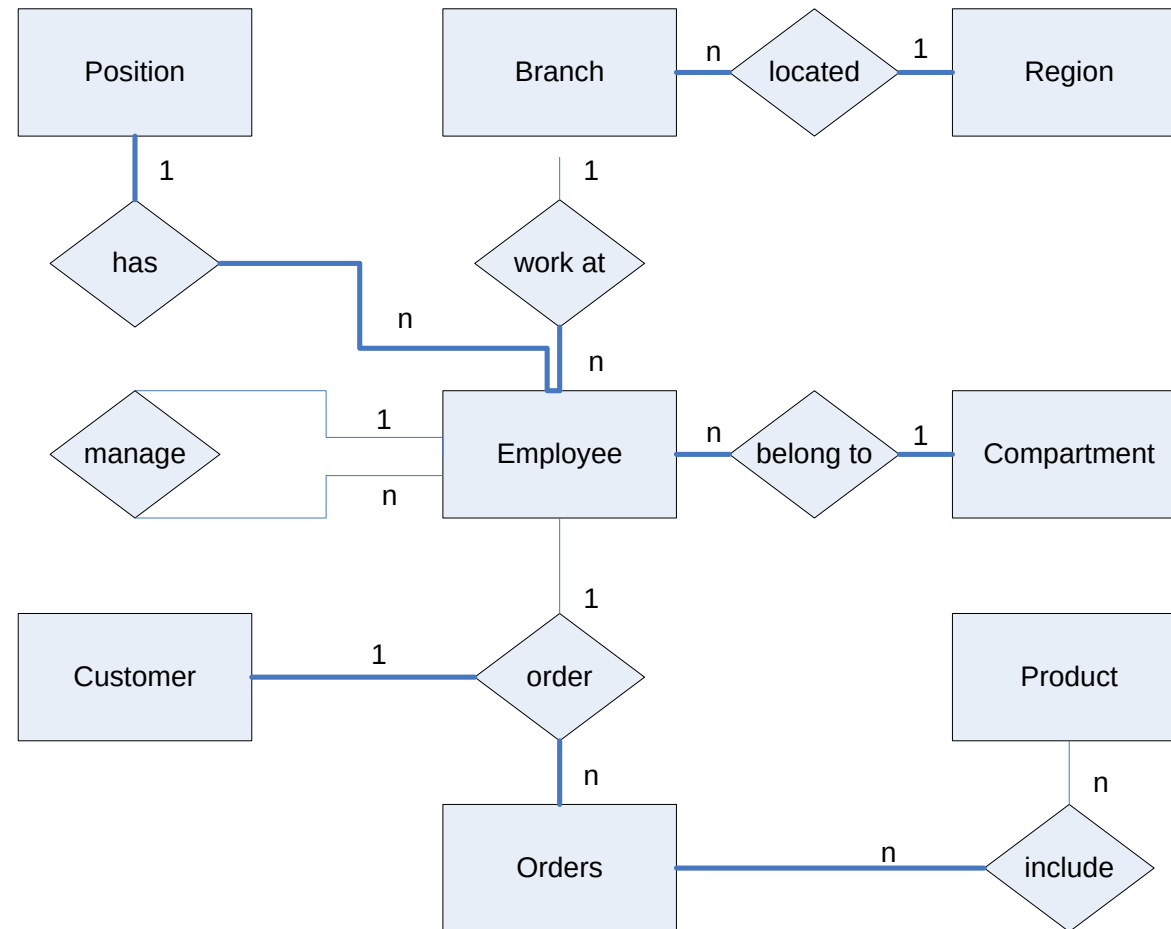
User label: MGR:CS:NA

User label: EMP:FS:NA

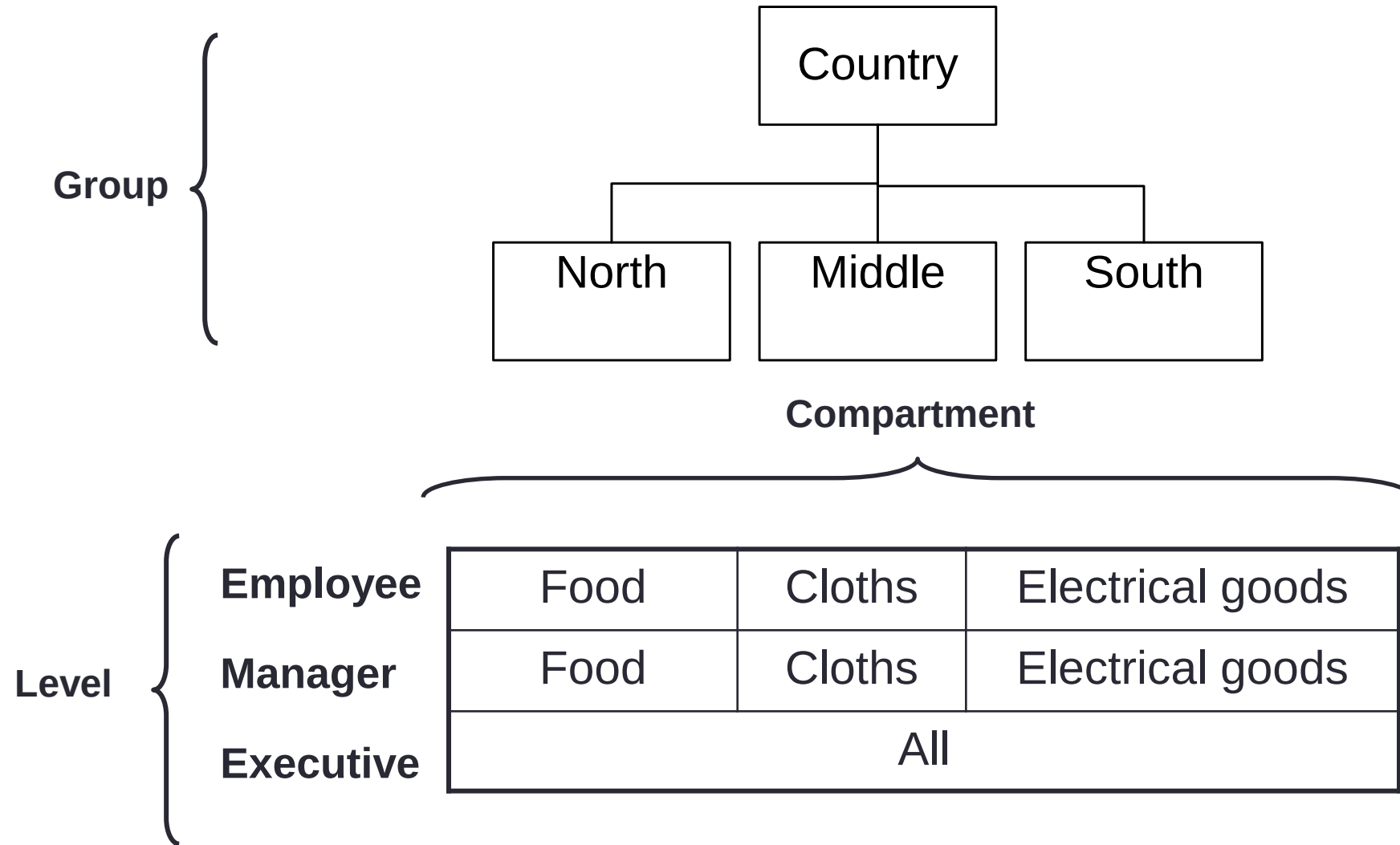
User label: EMP: : NA



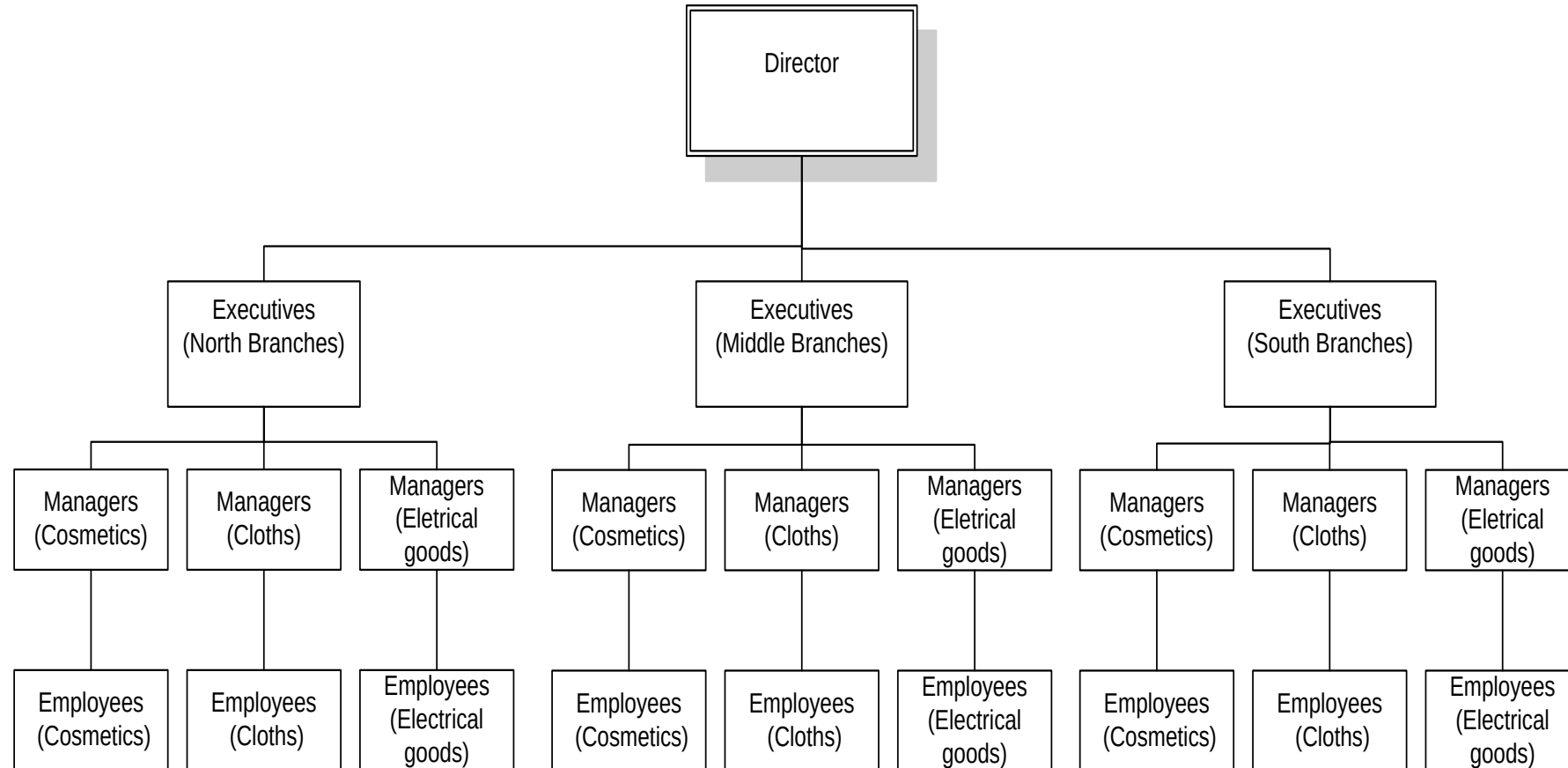
Project “Order Management” (1)



Project “Order Management” (2)



Project “Order Management” (3)



Protected ORDERS and PERSONAL INFORMATION Data

Outline

-
- 1 Introduction to MAC
 - 2 Proposed Models for MAC
 - 3 Case study: Oracle Label Security (OLS)
-

